

EXEMPLE GRATUIT / ÉDITION 2026

ÉVALUATION DE LA SÉCURITÉ RÉSEAU

Exemple de rapport exécutif et technique

ÉVALUER -> REMÉDIER -> VALIDER -> PROUVER

Organisation fictive et preuves techniques synthétiques. Cet exemple illustre la structure du reporting, l'analyse du risque, le niveau de détail de la remédiation et la méthode de validation. Aucun environnement client ou de production réel n'est représenté.

weownit.net / Network & Security Consulting

Ingénierie de sécurité guidée par le risque · Architecture · Remédiation · Validation

Synthèse exécutive de l'évaluation

Des constats techniques au risque métier et à une remédiation validée.

CONCLUSION DE L'ÉVALUATION

L'environnement synthétique présente des faiblesses courantes dans la protection du plan d'administration, la segmentation réseau, les accès privilégiés et la visibilité de sécurité. Le risque principal résulte de la combinaison d'une accessibilité trop large, d'une exposition privilégiée et d'une supervision incomplète.

RISQUE POUR L'ORGANISATION

Un poste utilisateur compromis peut créer un chemin vers le contrôle privilégié du réseau. Un accès est-ouest excessif augmente les possibilités de déplacement latéral, tandis qu'une journalisation incomplète peut réduire les capacités de détection et d'investigation.

RÉSULTAT

L'exemple montre comment weownit.net relie les preuves à l'impact métier, à la responsabilité de remédiation, aux critères de validation et au risque résiduel - au lieu de s'arrêter à une liste de constats techniques.

Contexte métier & actifs critiques

Les décisions de sécurité commencent par ce dont dépend l'activité.

CONTEXTE

ACME Manufacturing est une organisation fictive de 250 utilisateurs, avec un siège, deux agences, un ERP critique, des services internes, des accès distants et une administration réseau centralisée.

ACTIFS CRITIQUES

Pare-feu de périmètre; réseau d'administration; serveurs ERP et applicatifs; connectivité VPN; journalisation de sécurité centralisée; identités administratives privilégiées.

OBJECTIFS DE SÉCURITÉ

Préserver la disponibilité de la connectivité, l'intégrité des configurations privilégiées, la confidentialité des données, la séparation des zones de confiance et la traçabilité des actions d'administration.

Périmètre, hypothèses & méthodologie

Un modèle reproductible d'évaluation guidée par le risque.

PÉRIMÈTRE

Architecture, frontières de confiance, exposition administrative, segmentation, politiques de pare-feu, journalisation, accès privilégiés, sauvegarde de configuration et capacité de reprise.

MÉTHODE

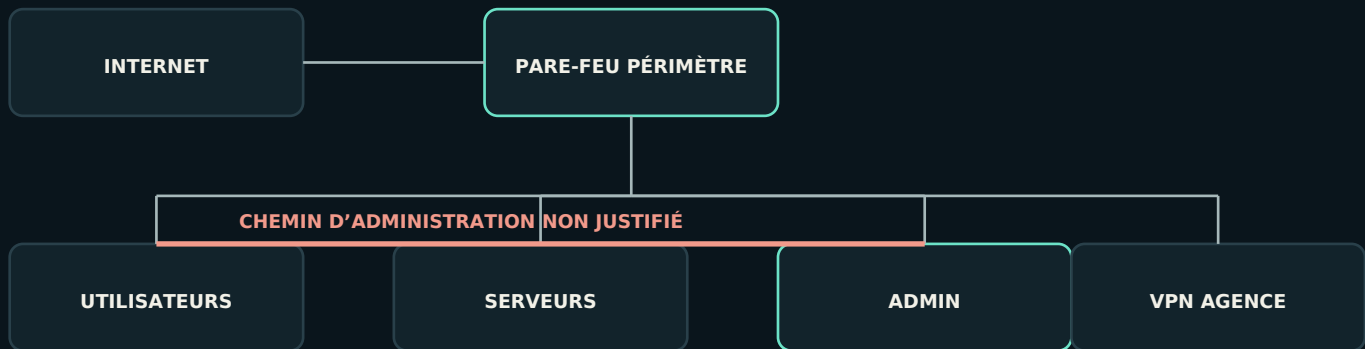
CONTEXTE -> ÉVALUER -> ANALYSER -> PRIORISER -> REMÉDIER -> VALIDER -> PROUVER

NIVEAU DE CONFIANCE

Cet exemple utilise des preuves SYNTHÉTIQUES / INFÉRÉES. Lors d'une mission réelle, chaque élément est classé comme observé, confirmé, inféré ou non testé.

Architecture & frontières de confiance

Identifier où une zone de confiance faible peut atteindre un contrôle privilégié.



ZONES DE CONFIANCE

Internet / Utilisateurs / Serveurs / Administration / Administration sécurité / VPN agence.

OBSERVATION PRINCIPALE

Le réseau utilisateurs peut atteindre les services d'administration HTTPS/SSH du pare-feu. Cette accessibilité affaiblit la frontière de confiance et crée un chemin inutile d'un poste moins fiable vers un contrôle de sécurité privilégié.

ÉTAT CIBLE

L'administration est autorisée uniquement depuis la zone de management ou via un chemin distant explicitement approuvé, protégé par MFA, comptes nominatifs, moindre privilège et journalisation centralisée.

Registre des risques & priorisation

Prioriser les scénarios de risque, pas les réglages isolés.

R-01 - EXPOSITION DU PLAN D'ADMINISTRATION

Probabilité 4/5 | Impact 5/5 | Risque inhérent : CRITIQUE |
Risque résiduel cible : FAIBLE

R-02 - ACCÈS EST-OUEST EXCESSIF

Probabilité 4/5 | Impact 4/5 | Risque inhérent : ÉLEVÉ |
Risque résiduel cible : MOYEN

R-03 - JOURNALISATION DE SÉCURITÉ INCOMPLÈTE

Probabilité 3/5 | Impact 4/5 | Risque inhérent : ÉLEVÉ |
Risque résiduel cible : FAIBLE

R-04 - ACCÈS PRIVILÉGIÉ SANS MFA

Probabilité 3/5 | Impact 5/5 | Risque inhérent : ÉLEVÉ |
Risque résiduel cible : FAIBLE

1	2	3	4	5
2	4	6	8	10
3	6	9	12	15
4	8	12	16	
5	10	15	20	25

F-001 - Plan d'administration accessible depuis la zone utilisateurs

Constat détaillé - ÉLEVÉ / PRIORITÉ 1

CHEMIN D'ATTAQUE Poste compromis -> Réseau utilisateurs -> Administration pare-feu -> Contrôle privilégié

ACTIF CONCERNÉ

Pare-feu de périmètre / plan d'administration.

OBSERVATION

Les services administratifs HTTPS et SSH sont accessibles depuis le réseau général des utilisateurs, et pas uniquement via le chemin d'administration dédié.

SCÉNARIO DE MENACE

Un poste compromis peut établir une connectivité vers le plan d'administration du pare-feu. Si l'attaquant obtient des identifiants administratifs ou exploite une autre faiblesse d'authentification, ce chemin peut conduire au contrôle privilégié.

PREUVES ILLUSTRATIVES

Source 10.20.10.25 (USER) -> 10.20.100.1. TCP/443 ACCESSIBLE; TCP/22 ACCESSIBLE. Type de preuve : SYNTHÉTIQUE.

IMPACT POTENTIEL

Modification non autorisée des politiques pare-feu, du routage, du VPN ou de la journalisation; interruption de service; perte d'intégrité du contrôle.

F-001 - Stratégie de contrôle & validation

Prévenir, limiter, détecter, rétablir - puis démontrer le résultat.

CHEMIN D'ATTAQUE Poste compromis -> Réseau utilisateurs -> Administration pare-feu -> Contrôle privilégié

PRÉVENIR

Réseau d'administration dédié; sources administratives approuvées; MFA pour l'accès privilégié; comptes administrateur nominatifs.

LIMITER

Administration fondée sur les rôles; moindre privilège; protocoles nécessaires uniquement; administration via VPN/OOB lorsque pertinent.

DÉTECTER

Journalisation des connexions administratives; surveillance des échecs; audit des changements de configuration; télémétrie centralisée.

RÉTABLIR

Sauvegarde de configuration validée; chemin d'accès d'urgence; procédure de retour arrière; responsabilité claire pour la reprise.

RISQUE DE MISE EN ŒUVRE

MOYEN - restreindre l'accès d'administration avant de confirmer une connectivité alternative peut entraîner un verrouillage. Vérifier d'abord l'accès console/OOB.

PREUVES DE VALIDATION

Admin approuvé -> HTTPS AUTORISÉ; USER -> HTTPS/SSH BLOQUÉ; Internet -> management BLOQUÉ; MFA OBLIGATOIRE; changements de configuration JOURNALISÉS.

RISQUE RÉSIDUEL ATTENDU

FAIBLE lorsque les sources d'administration sont restreintes, le MFA et les comptes nominatifs sont imposés, les actions privilégiées sont journalisées et les tests négatifs réussissent.

F-002 - Accès est-ouest excessif

Constat détaillé - ÉLEVÉ / PRIORITÉ 1

OBSERVATION

Une politique trop large du réseau utilisateurs vers les serveurs autorise davantage de services que nécessaire au fonctionnement normal.

ÉTAT ACTUEL

USER -> SERVER : accès large / type ANY.

VALIDATION

Test positif des flux applicatifs requis et tests négatifs vers les services de base de données et d'administration. Vérification des journaux de trafic refusé.

SCÉNARIO DE MENACE

Un poste compromis peut sonder ou joindre des services internes sans rapport avec la fonction métier de l'utilisateur, augmentant le nombre de cibles accessibles et le rayon d'impact potentiel.

ÉTAT CIBLE

USER -> APP : services nécessaires uniquement. USER -> DB/MGMT : bloqué sans justification explicite.

RISQUE RÉSIDUEL

MOYEN après application du moindre privilège et de la supervision, selon les dépendances applicatives et les exceptions formellement approuvées.

Feuille de route & preuves de clôture

Transformer les constats en actions mesurables, attribuées et vérifiables.

0-7 JOURS

Contenir l'exposition privilégiée : restreindre l'accès d'administration, vérifier l'accès d'urgence, imposer le MFA et désigner les responsables.

0-30 JOURS

Réduire la confiance inutile : remplacer l'accès utilisateur-vers-serveur trop large par des flux applicatifs approuvés et valider les dépendances avant application.

30-60 JOURS

Renforcer la visibilité et la reprise : centraliser la télémétrie pertinente, vérifier la rétention d'audit, tester la restauration de configuration et clarifier la responsabilité de reprise.

CRITÈRES DE CLÔTURE

OUVERT -> REMÉDIATION PLANIFIÉE -> IMPLÉMENTÉ -> VALIDATION REQUISE -> VÉRIFIÉ -> CLÔTURÉ.

DOSSIER DE PREUVES

Extrait de configuration pertinent, changement approuvé, tests positifs et négatifs, preuve d'audit, risque résiduel et acceptation du responsable.

RÉSULTAT CLIENT

Synthèse exécutive + registre technique des constats + liste de remédiation priorisée + observations d'architecture + plan de validation + preuves réutilisables pour la clôture.